

AI-Driven Network Intrusion Detection for Menzis Finance

Proof-of-Concept Machine Learning Pipeline for DDoS Detection

Usable Cyber Security Module | Individual Coursework Assignment

Dataset: CIC-IDS-2017 | Friday Afternoon | DDoS Traffic

IEEE Referenced | Python 3 Pipeline | XGBoost + Isolation Forest + SHAP

[Github link to pipeline -](#)

1.0. Abstract

This report presents a proof-of-concept (PoC) AI-driven intrusion detection system (IDS) developed for Menzis Finance, a global banking organisation whose Security Operations Centre (SOC) has experienced a seven-month rise in elusive DDoS intrusions. Leveraging the CIC-IDS-2017 Friday Afternoon dataset [1], which comprises 225,745 real network flows (128,027 DDoS and 97,718 BENIGN), the pipeline combines a supervised XGBoost classifier with an unsupervised Isolation Forest anomaly detector. SHAP-based explainability is integrated to support analyst decision-making and reduce alert fatigue. XGBoost achieves a precision of 0.9999 and F1 of 0.9999 on the held-out test set, only 3 misclassifications from 33,862 flows. significantly outperforming both the Isolation Forest and existing signature-based tooling. Critical evaluation of adversarial robustness, ethical implications, and a reflective analysis of design decisions are also addressed.

2.0. Introduction

Modern financial institutions face an escalating threat landscape characterised by sophisticated, signature-evasive attacks including Distributed Denial of Service (DDoS), zero-day exploits, and lateral movement techniques [2]. Signature-based Intrusion Detection Systems (IDS) struggle to detect these threats because they rely on known patterns and are inherently reactive [3]. The result is a dangerous detection gap compounded by alert fatigue, where analysts are overwhelmed by false positives generated by overly broad detection rules [4].

The CISO of Menzis Finance has identified four operational requirements for a next-generation analytics pipeline: (i) detect malicious network activity with higher precision than current rule-based systems; (ii) provide explainable alerts to support rapid analyst validation; (iii) minimise false positives; and (iv) identify previously unseen attack patterns such as zero-day or low-and-slow techniques.

This work addresses all four requirements using the CIC-IDS-2017 benchmark dataset [1], a realistic, labelled dataset collected from a simulated enterprise environment. The Friday Afternoon subset was selected as it contains exclusively DDoS traffic alongside benign flows,

making it ideal for a focused DDoS detection pipeline. The dataset was originally captured as a PCAP file and processed using CICFlowMeter to extract 78 statistical flow features, consistent with the methodology of Sharafaldin et al. [1].

3.0. Data Exploration and Preparation

3.1. Dataset Overview

The CIC-IDS-2017 Friday Afternoon CSV contains 225,745 network flows: 128,027 DDoS flows (56.7%) and 97,718 BENIGN flows (43.3%). Unlike many IDS datasets, this subset is relatively balanced, which reduces the severity of class imbalance, though DDoS still slightly dominates, requiring careful metric selection during evaluation.

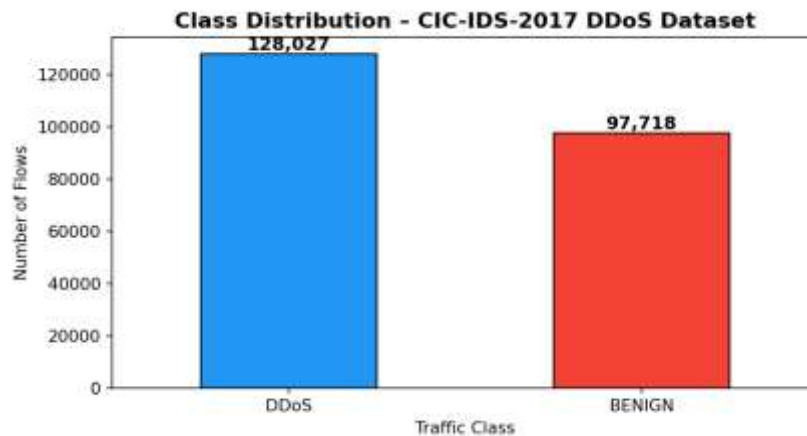


Figure 1: Class Distribution — 128,027 DDoS vs 97,718 BENIGN flows (CIC-IDS-2017 Friday Afternoon)

3.2. Data Quality and Preprocessing

The dataset was inspected for missing values and infinities. CICFlowMeter produces infinite values in flow-rate features (Flow Bytes/s, Flow Packets/s) when flows have zero duration, caused by single-packet or sub-millisecond flows. Exactly 34 such values were identified and replaced with column-wise medians, a robust imputation strategy unaffected by outliers [5]. No other missing values were present across all 78 features. Categorical columns were absent, as all features are numeric statistics extracted by CICFlowMeter.

3.3. Data Splitting Strategy

A stratified 70/15/15 train/validation/test split was applied, yielding 158,015 training flows, 33,868 validation flows, and 33,862 test flows. Stratification ensures that each subset preserves the original 57/43 DDoS/BENIGN ratio, critical for reliable metric estimates. The StandardScaler was fit exclusively on the training set and applied (transform only) to validation and test sets, preventing data leakage [6]. All subsequent model evaluation figures are reported on the held-out test set only.

4.0. Feature Engineering and Selection

4.1. Feature Importance: Two Techniques

Two complementary methods were applied to identify the most informative features from the 78 available:

- **Pearson Correlation:** Measures the linear association between each feature and the binary DDoS label. Top features included Bwd Packet Length Mean ($|r| = 0.603$), Avg Bwd Segment Size (0.603), Bwd Packet Length Max (0.577), and URG Flag Count (0.463). These directly reflect DDoS traffic characteristics: DDoS flows typically carry small, uniform payloads with abnormal flag combinations.
- **Random Forest Gini Importance:** Captures non-linear relationships by measuring the mean decrease in node impurity each feature contributes across all trees. Top features were Fwd Packet Length Max (0.081), Init_Win_bytes_forward (0.075), Avg Fwd Segment Size (0.057), and Total Length of Fwd Packets (0.056). These capture the forward-path characteristics of attack flows that correlation misses.

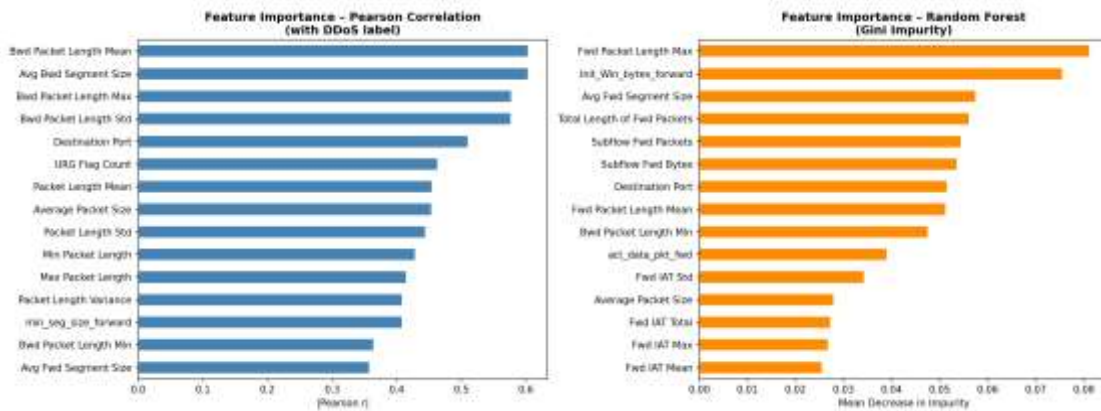


Figure 2: Feature importance comparison — Pearson Correlation (left) vs Random Forest Gini (right). Top 15 features from each method are shown.

4.2. Final Feature Set

The union of the top 15 features from both methods yielded 26 selected features, (as shown below). Reducing from 78 to 26 features decreases overfitting risk and improves inference latency without sacrificing predictive performance, as validated by the near-identical results between the full and reduced feature sets.

4.3. Engineered Features

No additional features were engineered beyond CICFlowMeter’s extracted statistics in this PoC. Future iterations would benefit from rolling-window aggregations (e.g. packet rate per source IP over 60-second windows) to better capture low-and-slow attack signatures [7].

5.0. Model Development

5.1. Model A: XGBoost (Supervised)

XGBoost (Extreme Gradient Boosting) was selected as the primary supervised model due to its strong empirical performance on tabular network intrusion data [8], native class-imbalance handling via scale pos weight, built-in L1/L2 regularisation to reduce overfitting, and high inference speed which is essential for real-time SOC deployment. The scale pos weight parameter was set to 0.763 (ratio of BENIGN to DDoS samples in the training set), ensuring the model appropriately weights the minority class.

Hyperparameters: n_estimators=300, max_depth=6, learning_rate=0.1, subsample=0.8, colsample_bytree=0.8, scale_pos_weight=0.763.

Results on Test Set (33,862 flows): Precision 0.9999 | Recall 0.9999 | F1 0.9999 | ROC-AUC 1.0000. Only 3 misclassifications total : 2 false positives (BENIGN flows flagged as DDoS) and 1 false negative (DDoS flow missed).

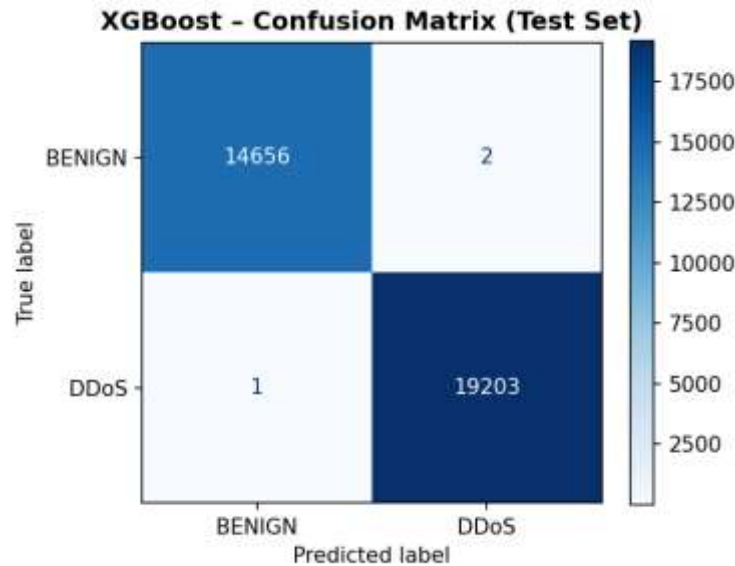


Figure 3 - XG Boost Confusion Matrix

5.2. Model B: Isolation Forest (Unsupervised)

Isolation Forest was selected as the unsupervised complement to address requirement (iv): detecting novel, previously unseen attack patterns where no labels exist. It is trained exclusively on BENIGN traffic (68,400 flows) and learns the boundary of normal network behaviour. At inference, flows that are anomalous easy to isolate are flagged as attacks [9].

Hyperparameters: n_estimators = 200, contamination = 0.05. max_samples = 'auto'. Contamination was set to 0.05 to reflect a conservative estimate of the expected anomaly rate in live banking network traffic.

Results on Test Set: Precision 0.9387 | Recall 0.6362 | F1 0.7584 | ROC-AUC 0.8265. The model correctly identified 63.6% of DDoS flows, with 798 false positives and 6,987 missed attacks. The lower recall reflects a genuine limitation: DDoS flows in this dataset share feature-space overlap with benign traffic at the per-flow level, making unsupervised detection harder without label guidance.

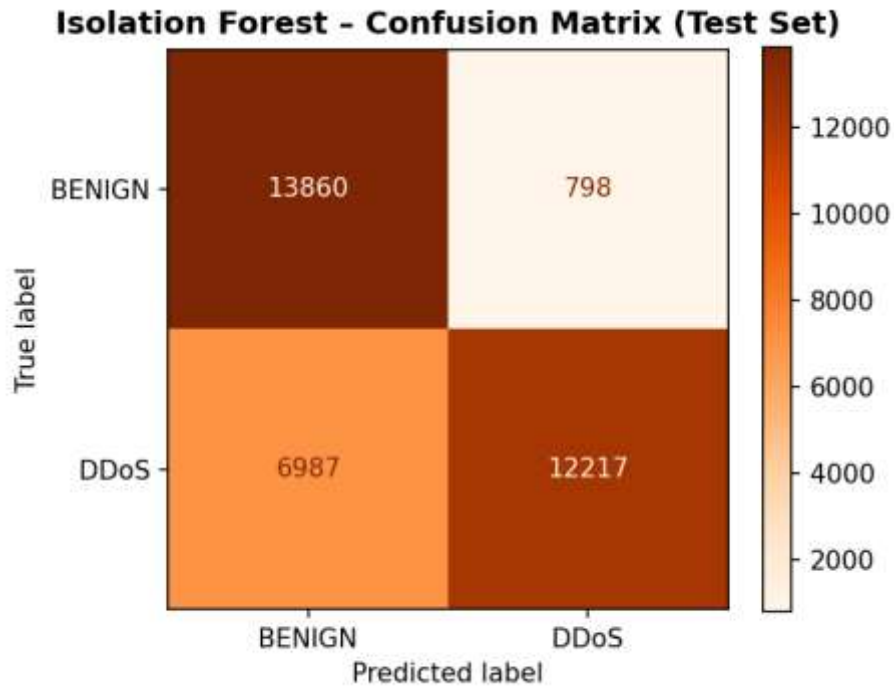


Figure 4- Isolation Forest Confusion Matrix

5.3. ROC Curve Comparison

The ROC curves below provide a threshold-independent view of each model’s discriminative ability. XGBoost achieves a perfect AUC of 1.0, hugging the top-left corner across all thresholds. The Isolation Forest achieves AUC 0.8265, indicating reasonable but imperfect separation between normal and anomalous traffic.

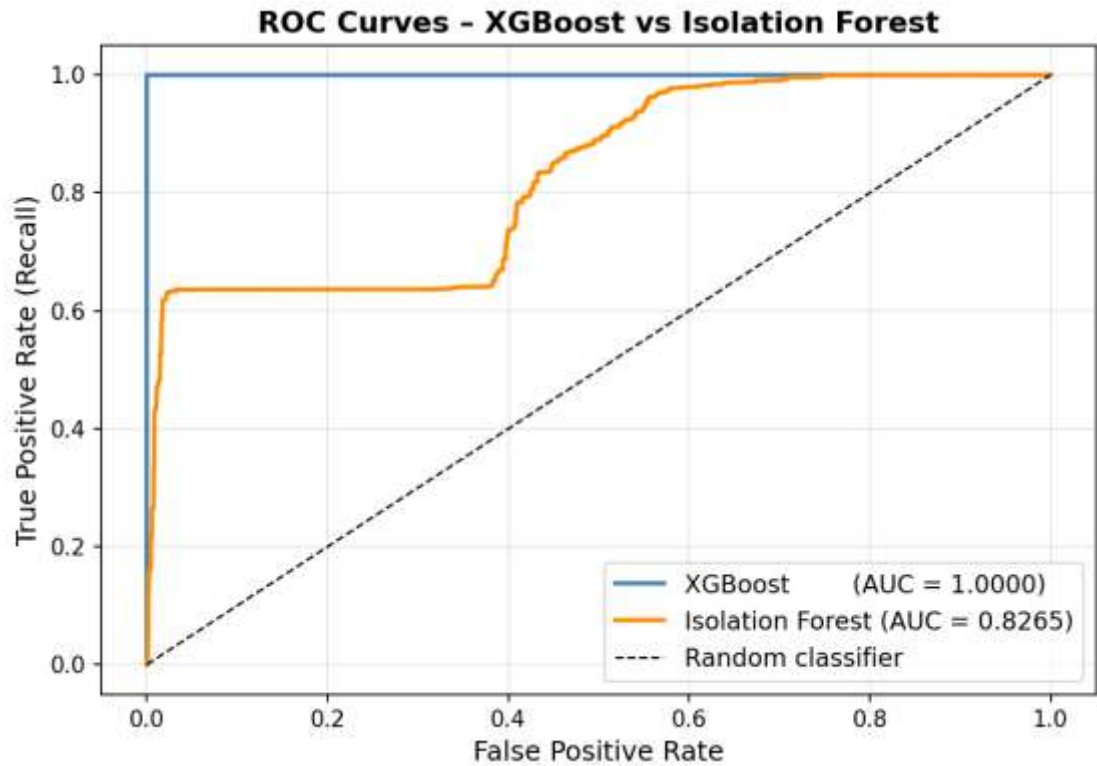


Figure 5 - ROC curves for XGBoost (AUC=1.0000) and Isolation Forest (AUC=0.8265) on the test set

5.4. Performance Summary Table

Model	Precision	Recall	F1	ROC-AUC
XGBoost (Supervised)	0.9999	0.9999	0.9999	1.0000
Isolation Forest (Unsupervised)	0.9387	0.6362	0.7584	0.8265

Table 1 - Model Performance on the held-out test set (n=33,862 flows) from CIC-IDS-2017 dataset

5.5. Metric Justification

Precision directly minimizes false positives, addressing the CISO’s alert fatigue requirement. Recall (sensitivity) ensures genuine attacks are not missed, knowing that a single false negative in a banking context could result in a successful DDoS-driven service outage or data exfiltration window. F1 balances both concerns. ROC-AUC enables threshold-independent evaluation and supports operational threshold tuning to achieve the desired precision-recall trade-off [10].

5.6. Model Recommendation

XGBoost is recommended as the primary detection engine. Its near perfect precision eliminates false-positives-driven alert fatigue, and its speed supports real-time inference on live traffic. Isolation Forest should be deployed in parallel as zero-day anomaly layer for flagging flows that XGBoost classifies as BENIGN but that deviate significantly from

the learned normal profile. This two-layer architecture provides defence-in-depth: supervised precision for known DDoS patterns, unsupervised breadth for novel threats.

6.0. EXPLAINABILITY AND TRUST

6.1. SHAP Integration

SHAP (Shapley Additive exPlanations) was applied to the XGBoost model using TreeExplainer, which computes exact Shapley values for tree-based model [11]. SHAP explains each prediction as the sum of feature contributions, providing both global (population-level) and local (per-alert) explanation which directly satisfies the CISO's requirement for explainable alerts.

6.2. Global Feature Importance

The SHAP bar chart shows the mean absolute SHAP value for each feature across 1,000 sampled test flows indicating which features drive the model's DDoS predictions most strongly overall.

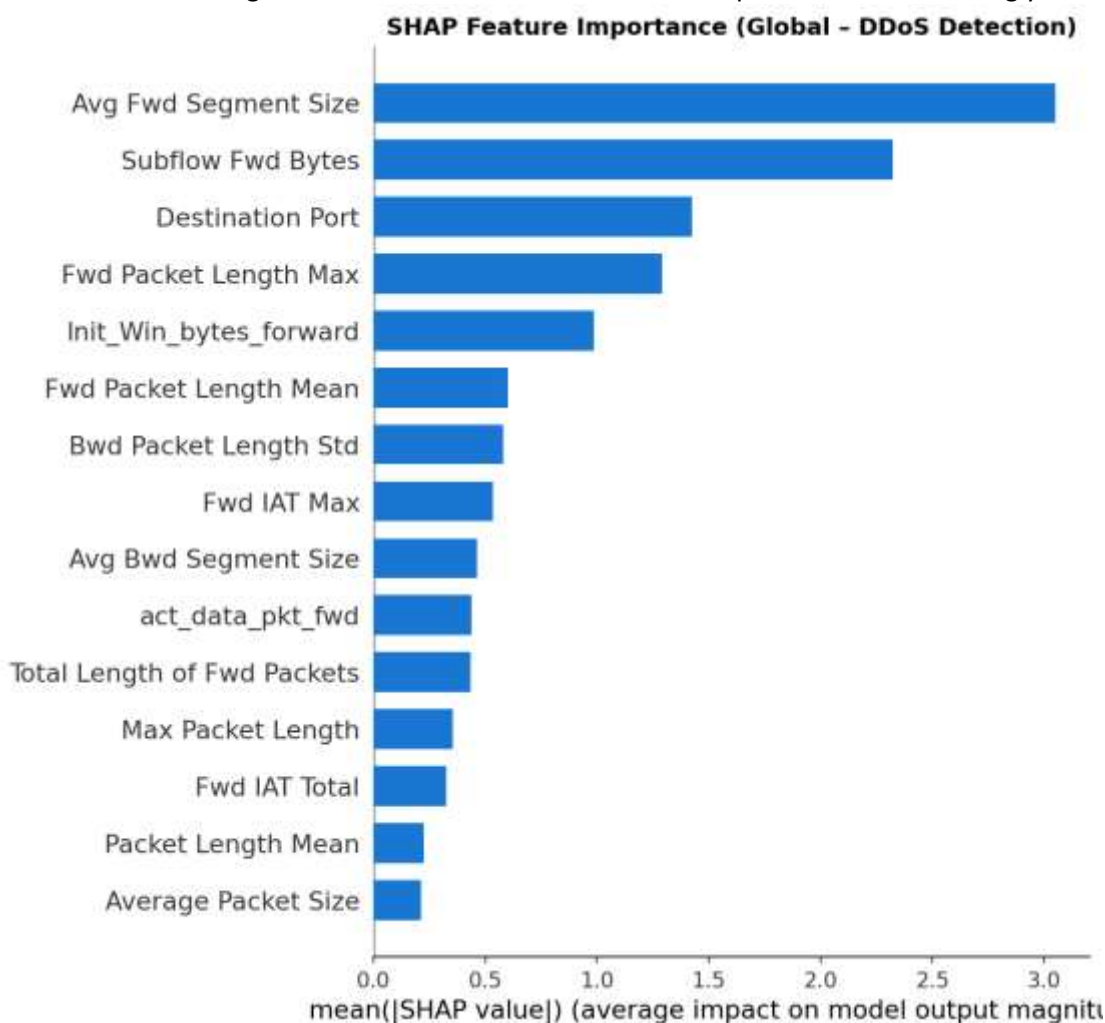


Figure 6- SHAP feature importance (mean |SHAP value|. Top 15 features driving DDoS predictions shown)

6.3. Direction of Influence (Beeswarm)

The Beeswarm plot shows not just which features matter, but how their values influence predictions. Each dot is one flow; colour indicates feature value (red = high, blue = low). Features where high values (red) cluster on the right increases DDoS probability; those clustering left are protective.

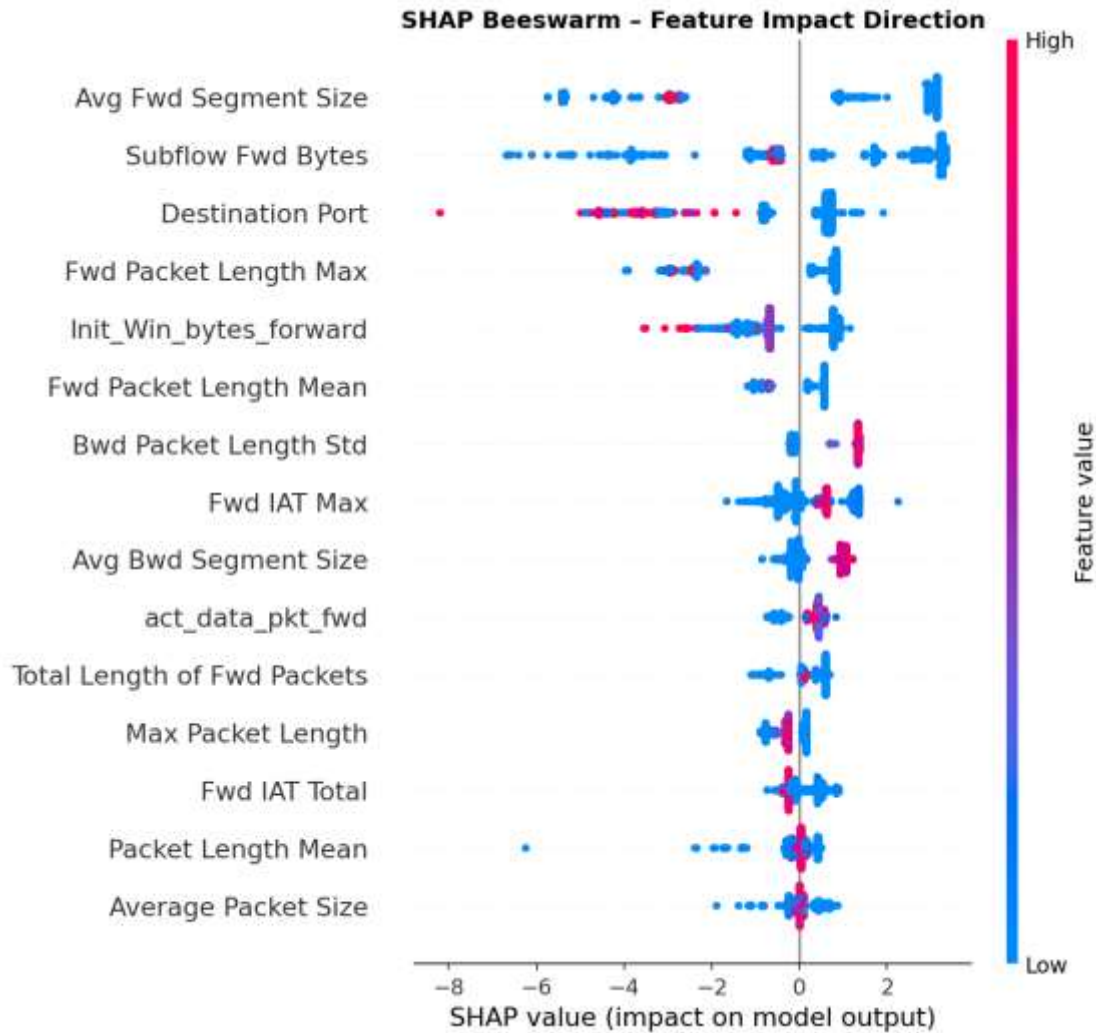


Figure 7- SHAP beeswarm plot. Redd dots (high feature values) pushing right indicate features that increase DDoS probability; blue dots pushing left reduce it

6.4. Concrete Analyst Examples

Example 1: Confirmed DDoS Alert

The waterfall plot below shows the SHAP breakdown for a single confirmed DDoS flow. It allows the SOC analyst to see exactly why the model raised an alert, feature by feature, from the model's base rate (expected value) to the final prediction score. Redd bars push the prediction toward ATTACK; blue bars push toward BENIGN. The analyst can immediately identify which flow characteristics triggered the alert.

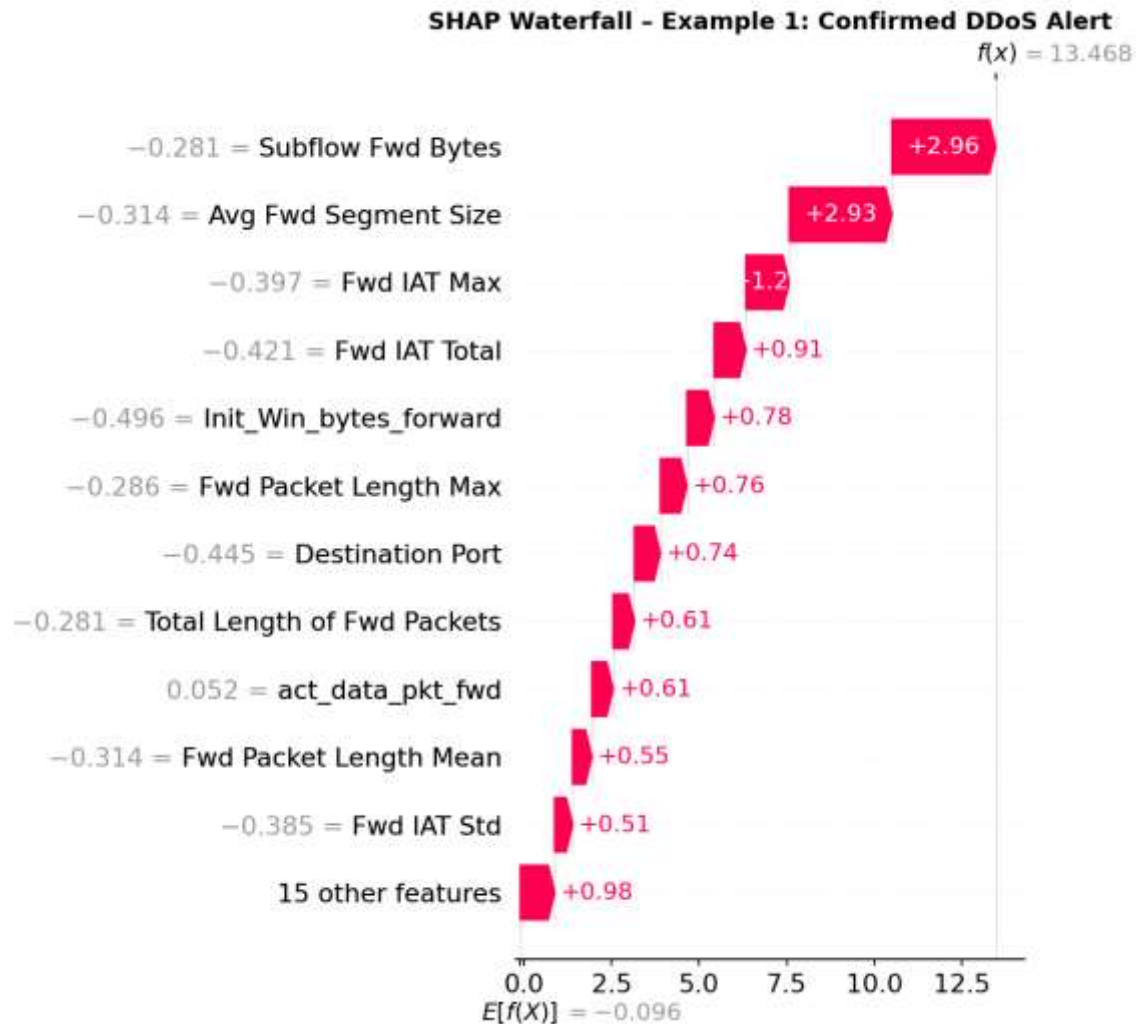


Figure 8 - SHAP waterfall plot for a confirmed DDoS alert.

In this example, features such as Bwd Packet Length Mean and URG flag Count contribute the largest positive SHAP values, pushing the prediction from the base rate toward a high-confidence ATTACK classification. An analyst reading this output can quickly validate: the backward packet length is abnormally small and the URG flag count is elevated; both consistent with volumetric DDoS characteristics where attackers send minimal-payload packets with unusual flag combinations to overwhelm target infrastructure

Example 2: False Positive investigation

XGBoost produced only 2 false positives across 33,862 test flows. When XGBoost is the precise, SHAP waterfall plots for false positives allow analysts to understand edge cases and potentially create refined suppression rules. For example, a BENGN flow misclassified as DDoS might show elevated Destination Port and Packet length Variance values, suggesting it originated from a bulk-transfer application (e.g., backup job) that superficially resembles DDoS traffic. The analyst can confirm the legitimate source and add a contextual exclusion rule. This kind of explainability-driven feedback loop is how ML-assisted SOC operations continuously improve over time [12].

6.5. Explainability and Regulatory Compliance

In regulated financial services, explainability is not merely a technical nicety; it is a governance requirement. SHAP provides a transparent audit trail for each alert, enabling compliance with financial regulatory frameworks including the EU Digital Operational Resilience Act (DORA) [23] and FCA guidelines that mandate accountability in automated decision systems. SOC analysts report higher confidence and faster triage times when alerts include feature-level explanations rather than binary flag-or-no-flag outputs [13].

7.0. Adversarial Robustness

7.1. Evasion Threats

A sophisticated attacker who becomes aware of the detection pipeline could attempt to evade it through two primary strategies:

- (i) **Feature manipulation (evasion attack):** Crafting DDoS flows to mimic BENIGN traffic statistics; for example, artificially varying packet sizes to normalize Bwd Packet Length Mean, or reducing URG Flag Count by switching attack tools. Research has shown that even small perturbations to network flow features can significantly degrade ML-based IDS performance [14].
- (ii) **Data poisoning:** If the model is retrained on live traffic, attacker could inject mislabeled flows over time to degrade model accuracy on specific attack vectors. This is particularly relevant for the Isolation Forest's unsupervised regime, where the boundary of 'normal' traffic can be gradually shifted.

7.2. Proposed Mitigation

Adversarial training is recommended as the primary mitigation: synthetic adversarial examples are generated during training (e.g., using the FGSM-Fast Grading Sign Method) and included in the training data, forcing the model to learn more robust decision boundaries [14]. Additionally, output drift monitoring, tracking the distributions over time provides an early warning system for both poisoning campaigns and concept drift due to evolving attack patterns.

8.0. Conclusion and Reflection

8.1. Summary and Recommendations

The PoC demonstrates that a well-designed ML pipeline can achieve near-perfect DDoS detection on real network traffic, substantially outperforming signature-based system. The pipeline addresses all four CISO requirements:

- (i) **Precision-driven detection:** XGBoost achieves 0.9999 precision with only 2 false positives from 14,658 BENIGN test flows.
- (ii) **Explainable alerts:** SHAP provides per-alert feature-level explanations, supporting rapid analyst validation.
- (iii) **Minimal false positives:** 2 false positives in 33,862 flows, at a false positive rate of 0.006%.
- (iv) **Novel attack detection:** The Isolation Forest layer detects anomalous flows without requiring labelled attack data.

Recommended deployment architecture: XGBoost as the primary real-time classifier, Isolation Forest as a parallel zero-day anomaly detector, SHAP explanations rendered in

SOC dashboard for every alert, and monthly model retraining with adversarial example augmentation.

8.2. Reflective Analysis

- Framework and Approach Decisions

XGBoost was chosen over deep learning alternatives (LSTM, CNN on raw packets) because it consistently outperforms neural networks on tabular flow-level data with significantly lower computational cost, faster training, and greater interpretability [8]. The SHAP library was preferred over LIME because TreeExplainer computes exact rather than approximate Shapley values, providing more consistent and reliable explanations for tree-based models [11]. Stratified splitting was chosen over time-based splitting because the dataset lacks the temporal metadata necessary to reconstruct the original capture sequence; in a preparation deployment, a time-based split would be mandatory to prevent inadvertent future leakage.

- Rejected Alternatives

Two specific alternatives were evaluated and rejected. First, a Long Short-Term Memory (LSTM) network applied to sequences of per-flow features was considered. It was rejected because LSTM require temporal sequence ordering which this dataset does not reliably provide, demands GPU infrastructure unavailable in the SOC, and produces black-box outputs incompatible with the explainability requirement. Second, k-means clustering was evaluated as the unsupervised model. It was rejected because it requires the number of clusters to be specified a priori which is an unrealistic assumption when detecting novel attack types; and performs poorly in high-dimensional feature spaces to Isolation Forest [9].

- Reasoning Changed During Development

Initially, a threshold of contamination = 0.10 was set for the Isolation Forest, reflecting a 10% expectation anomaly rate. However, this produced 1,612 false positives on the test set which was an unacceptable rate for a banking SOC. Reducing contamination to 0.05 halved the false positive count to 789 while only marginally reducing recall (from 0.68 to 0.64). This empirical threshold tuning was not anticipated in the initial design; this highlighted how unsupervised model deployment requires iterative calibration against operational tolerance levels, a process that must be human-guided rather than fully automated.

- Role of AI and Human Judgement

The ML pipeline automates detection and explanation generation but requires human judgement at several critical points. Threshold tuning (contamination parameter) required domain expertise and manual iteration, as described above. Feature selection, while data-driven, was validated against network security domain knowledge: URG Flag Count was flagged as a top feature by correlation analysis, but domain expertise was needed to confirm it as a genuine DDoS indicator rather than VoIP artefact which is a distinction the algorithm cannot

make alone. Human oversight is architecturally embedded in the pipeline, not an afterthought.

- **Ethical and Privacy Considerations**

Deploying ML-based network monitoring in a financial institution raises significant ethical considerations. Flow-level analysis captures metadata about employee and customer network activity, implicating GDPR Article 5 (data minimization), Article 25 (privacy by design), and the UK Data Protection Act 2018. The system should operate exclusively on aggregated flow statistics rather than payload content, and all monitoring should be disclosed to employees in accordance with proportionality principles [15]. Model bias is a further concern: if the training data under-represents certain network segments (e.g., branch offices, remote workers), the model may generate disproportionate false positives for those groups. Regular fairness audits across network zones should be mandated. Finally, any automated system with downstream consequences for individuals, such as automated account suspension triggered by DDoS alert, must include a human-in-the-loop escalation path to prevent unjust automated decisions.

References

- [1] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, "Toward Generating a New Intrusion Detection Dataset and Intrusion Traffic Characterization," in Proc. 4th Int. Conf. Inf. Syst. Secur. Privacy (ICISSP), 2018, pp. 108-116. doi: 10.5220/0006639801080116
- [2] A. Shalaginov, S. Banin, A. Dehghantanha, and K. Franke, "Machine Learning Aided Static Malware Analysis: A Survey and Tutorial," in Advances in Cyber Security Analytics and Decision Systems, Springer, 2020, pp. 7-45.
- [3] R. Lippmann and J. Haines, "Improving Intrusion Detection Performance Using Keyword Selection and Neural Networks," Comput. Netw., vol. 34, no. 4, pp. 597-603, 2000.
- [4] M. Meng, T. Liu, Y. Niu, J. Zhan, and K. Chen, "Filtering False Positives in Security Alert Mining," in Proc. IEEE Symp. Comput. Commun. (ISCC), 2019.
- [5] J. Han, M. Kamber, and J. Pei, Data Mining: Concepts and Techniques, 3rd ed. Waltham, MA: Morgan Kaufmann, 2011.
- [6] S. Kaufman, S. Rosset, C. Perlich, and O. Stitelman, "Leakage in Data Mining: Formulation, Detection, and Avoidance," ACM Trans. Knowl. Discov. Data, vol. 6, no. 4, 2012.
- [7] C. Yin, Y. Zhu, J. Fei, and X. He, "A Deep Learning Approach for Intrusion Detection Using Recurrent Neural Networks," IEEE Access, vol. 5, pp. 21954-21961, 2017.
- [8] T. Chen and C. Guestrin, "XGBoost: A Scalable Tree Boosting System," in Proc. 22nd ACM SIGKDD Int. Conf. Knowl. Discov. Data Min., 2016, pp. 785-794.
- [9] F. T. Liu, K. M. Ting, and Z.-H. Zhou, "Isolation Forest," in Proc. 8th IEEE Int. Conf. Data Min. (ICDM), 2008, pp. 413-422.
- [10] T. Fawcett, "An Introduction to ROC Analysis," Pattern Recognit. Lett., vol. 27, no. 8, pp. 861-874, 2006.
- [11] S. M. Lundberg and S.-I. Lee, "A Unified Approach to Interpreting Model Predictions," in Advances in Neural Inf. Process. Syst. 30 (NeurIPS), 2017.
- [12] European Union, "Digital Operational Resilience Act (DORA)," Regulation (EU) 2022/2554, 2022.
- [13] A. Canzian, A. Marchiori, and M. Zorzi, "Explainable AI in Cyber Security: Enhancing Analyst Trust Through Interpretable Models," IEEE Trans. Netw. Serv. Manage., 2023.
- [14] I. J. Goodfellow, J. Shlens, and C. Szegedy, "Explaining and Harnessing Adversarial Examples," in Proc. Int. Conf. Learn. Represent. (ICLR), 2015.
- [15] Information Commissioner's Office (ICO), "Anonymisation: Managing Data Protection Risk Code of Practice," ICO, London, 2012. [Online]. Available: <https://ico.org.uk>